

## Theoretical Foundation

### OWASP Risk Rating Model

OWASP defines risk conceptually as:

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

This model separates:

- The probability of occurrence (Likelihood)
- The severity of consequences (Impact)

### NIST SP 800-30 Rev. 1

NIST defines risk as:

*“A function of the likelihood of a given threat-source exercising a particular potential vulnerability and the resulting impact of that adverse event.”*

However, NIST clarifies:

*“Risk assessors do not define a likelihood function in the statistical sense... Instead, risk assessors assign a score based on available evidence.”*

This allows likelihood to be operationalized as a detection-based indicator rather than a statistical probability.

### CVSS v4.0 (FIRST)

The CVSS specification states:

*“The Base Score reflects the severity of a vulnerability according to its intrinsic characteristics which are constant over time.”*

This means:

- Severity (Impact) is intrinsic.
- It does not change based on detection frequency.
- It is independent of environmental monitoring counts.

*Therefore, the CVSS Base Score is used as the Impact component of the risk model.*

## Likelihood as Presence

Since our system is:

- Passive scanning only
- Does not estimate statistical probability
- Does not perform predictive modeling
- Does not implement intrusion prevention

Likelihood is operationalized as:

$$Presence \in \{0, 1\}$$

Where:

- 1 = vulnerability or threat condition detected
- 0 = not detected

*This aligns with NIST guidance, which states that likelihood may be assigned based on available evidence.*

## FINALIZED RISK COMPUTATION MODEL

### Per-Item Risk

$$R_i = P_i \times CVSS_i$$

Where:

- $P_i$  = Presence Indicator (0 or 1)
- $CVSS_i$  = CVSS 4.0 Base Score (Base Score from our Data Sets)

### Total Observed Risk (Per Network)

$$R_{observed} = \sum_{i=1}^7 (P_i \times CVSS_i)$$

Since the system scope includes 7 items:

- 4 configuration vulnerabilities
- 3 detected threats

Essence: Add all CVSS scores of the detected items before normalizing into a percentage

### Maximum Possible Risk

$$R_{max} = \sum_{i=1}^7 CVSS_i$$

Maximum Risk represents:

- The theoretical worst-case exposure within the defined dataset (all 7 items present).

| ID                    | Item                                        | Risk Score |
|-----------------------|---------------------------------------------|------------|
| WFVT-001              | Open System Authentication                  | 9.4        |
| WFVT-002              | Weak or Deprecated Cryptographic Algorithms | 9.4        |
| WFVT-003              | Wi-Fi Protected Setup (WPS) Enabled         | 7.6        |
| WFVT-004              | Protected Management Frames (PMF) Disabled  | 7.1        |
| WFVT-005              | Evil Twin Attack                            | 9.3        |
| WFVT-006              | Deauthentication Attack                     | 8.5        |
| WFVT-007              | MAC Address Spoofing Attack                 | 9.4        |
| Maximum Possible Risk |                                             | 60.7       |

*This value is constant for all networks because the dataset is fixed.*

### Normalization to Percentage

$$WiFiSecurityRiskScore\% = \frac{R_{observed}}{R_{max}} \times 100$$

Purpose of normalizing to a percentage:

- Converts aggregate raw risk score into a 0–100 scale
- Preserves proportional relationships
- Enables comparison across networks
- Prevents raw score misinterpretation

*Normalization does not alter CVSS severity; it scales relative exposure within scope.*

## Risk Classification Scale

Reference/Basis:

| CVSS v4.0 Ratings |                      |
|-------------------|----------------------|
| Severity          | Severity Score Range |
| None*             | 0.0                  |
| Low               | 0.1-3.9              |
| Medium            | 4.0-6.9              |
| High              | 7.0-8.9              |
| Critical          | 9.0-10.0             |

Normalized (into Percentile)

| Classification/Severity | Risk%   |
|-------------------------|---------|
| None                    | 0%      |
| Low                     | 1-39%   |
| Medium                  | 40-69%  |
| High                    | 70-89%  |
| Critical                | 90-100% |

*This maintains conceptual alignment with standardized CVSS severity ranges.*

## Role of Occurrences

Occurrences are used exclusively for wireless threat detections, not for configuration vulnerabilities.

### For Configuration Vulnerabilities (State-Based)

- Open Authentication
- Weak/Deprecated Cryptographic Algorithms
- WPS Enabled
- PMF Disabled

These are evaluated as static configuration states.

$$P_{vulnerability} = \begin{cases} 1 & \text{if misconfiguration detected} \\ 0 & \text{otherwise} \end{cases}$$

No occurrence count is used.

### For Threats (Event-Based)

- Evil Twin
- Deauthentication
- MAC Address Spoofing

These are event-driven detections.

$$P_{threat} = \begin{cases} 1 & \text{if occurrences} \geq 1 \\ 0 & \text{otherwise} \end{cases}$$

Essence: Even if there are multiple detected threats or occurrences in general, 1 pa rin.

Occurrences:

- Serve as detection evidence
- Trigger the Presence indicator
- Are displayed for analytics and reporting
- Do not modify the CVSS impact
- Do not increase intrinsic severity
- Do not act as weighting factors

**Justification:**

### CVSS 4.0

*“The Base Score reflects the severity of a vulnerability according to its intrinsic characteristics which are constant over time and across user environments.”*

Which:

- Severity does not change because you observed it multiple times.

- Frequency of detection does not modify Base Score.

Therefore,

*Occurrences cannot increase CVSS severity.*

## **NIST SP 800-30**

*“Risk assessors do not define a likelihood function in the statistical sense.”*

*“Instead, risk assessors assign a score (or likelihood assessment) based on available evidence, experience, and expert judgment.”*

Supports:

- We do not need statistical modeling of frequency
- Detection evidence can determine the likelihood score
- Binary presence (detected vs not detected) is acceptable

*Occurrences serve as available evidence, not severity multipliers.*

In essence,

- CVSS says severity is constant
- CVSS defines impact as consequence magnitude
- NIST says likelihood is evidence-based
- NIST does not require statistical occurrence modeling

## Summary of Threats & Vulnerabilities CVSS 4.0 Risk Score

|          |                                             |     |          |                                                                 |
|----------|---------------------------------------------|-----|----------|-----------------------------------------------------------------|
| WFVT-001 | Open System Authentication                  | 9.4 | Critical | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L |
| WFVT-002 | Weak or Deprecated Cryptographic Algorithms | 9.4 | Critical | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L |
| WFVT-003 | Wi-Fi Protected Setup (WPS) Enabled         | 7.6 | High     | CVSS:4.0/AV:A/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:L/SC:L/SI:L/SA:L |
| WFVT-004 | Protected Management Frames (PMF) Disabled  | 7.1 | High     | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:H/SC:N/SI:N/SA:N |
| WFVT-005 | Evil Twin Attack                            | 9.3 | Critical | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:N/SC:H/SI:H/SA:N |
| WFVT-006 | Deauthentication Attack                     | 8.5 | High     | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:H/SC:L/SI:H/SA:H |
| WFVT-007 | MAC Address Spoofing Attack                 | 9.4 | Critical | CVSS:4.0/AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L |